

Cyber Tabletop Exercise

Enhanced Version: Data Integrity Attack on AML and Sanctions Screening

Scenario title	TTX Scenario 10 – Data integrity attack on AML and sanctions screening
Sector	Financial services
Primary audience	Executive, operational, technical, compliance, legal, and crisis-management stakeholders
Format	Facilitated discussion-based tabletop exercise
Recommended duration	90 minutes core session + 30 minutes debrief
Version	Enhanced v2.0, generated 13 July 2026
Source inputs	Original PDF scenario and accompanying evaluation JSON uploaded by the user

Confidential document. For internal distribution and by authorization only. Do not print or transmit externally unless approved by the exercise sponsor.

This version preserves the original AML/sanctions screening integrity-failure scenario while explicitly integrating the evaluation recommendations: deeper adversary sequencing, concrete environmental detail, confirmed-vs-assumed evidence handling, measurable success criteria, exercise-control mechanics, formal scoring, and a richer MITRE ATT&CK; mapping.

Table of Contents

Table of Contents

2

1. Introduction

4

1.1 Improvement Areas Explicitly Integrated

4

2. Exercise Objectives and Success Criteria

4

2.1 Measurable Exercise Success Criteria

5

3. Scope

5

3.1 In Scope

5

3.2 Out of Scope

5

3.3 Exercise Assumptions

6

4. Intended Participants

6

5. Exercise Structure and Rules of Engagement

6

5.1 Exercise-Control Roles

7

5.2 Control Coordination Mechanisms

7

6. Scenario Background

7

7. Environment and Asset Overview

8

7.1 Simplified Platform Architecture

8

7.2 Logical Payment and Screening Flow

8

7.3 Detection Telemetry to Use During the Exercise

8

7.4 Exercise Notification and Escalation Triggers

9

8. Scenario Narrative

9

9. End-to-End Adversary Pathway

9

10. Evidence Discipline: Confirmed Facts vs Assumptions

10

11. Master Timeline and Inject Summary

11

12. Detailed Injects and Facilitation Guide

11

Inject 1 — Abnormal alert volume collapse

11

Inject 2 — Control validation fails

12

Inject 3 — Transaction lookback and regulator pressure	13
Inject 4 — Root cause uncertainty deepens	14
Inject 5 — Recovery decision and retrospective screening results	16
Inject 6 — Post-incident obligations and control uplift	17
13. Key Decision Points	18
14. Discussion Questions by Audience	19
15. Technical and Business Impact Assessment	19
16. Communications and Regulatory Considerations	19
16.1 Regulator-Ready Fact Pattern	19
16.2 Messaging Principles	20
17. Roles and Responsibilities Matrix	20
18. Facilitator Guide	20
18.1 Desired Behaviors to Observe	20
18.2 Common Gaps to Test	21
18.3 Stretch Questions	21
19. Evaluation Model and Scoring Rubric	21
19.1 Observer Capture Sheet	22
20. Debrief and Lessons Learned	22
20.1 Suggested After-Action Outputs	23
21. Suggested Improvement Actions	23
22. Source Mapping and Ready-to-Use Opening Script	24
22.1 Source Mapping	24
22.2 Opening Script	24
23. Glossary	24
24. MITRE ATT&CK; Mapping	25

1. Introduction

This tabletop exercise simulates a cyber-enabled integrity compromise affecting the bank's AML and sanctions screening platform. The core event is a silent fail-open condition: transactions continue to flow, but expected AML and sanctions checks are incomplete, bypassed, or recorded without reliable screening outcomes.

The exercise tests how the organization detects a failure in a critical compliance control, validates whether the condition is operational or malicious, contains payment and regulatory exposure, preserves evidence, reconstructs affected transactions, conducts retrospective screening, and safely restores trust in the control environment.

The scenario is fictional and designed for discussion. It does not imply a real weakness in any bank, platform, vendor, or regulator-facing process.

1.1 Improvement Areas Explicitly Integrated

Evaluation finding	Enhancement in this version
Cyber accuracy needed a complete adversary pathway.	Added a plausible end-to-end adversary chain from credential compromise through rule/data manipulation and recovery hunting.
Need to specify Initial Access, Execution, Persistence, Privilege Escalation, Defense Evasion, Discovery, credential use, and Impact.	Mapped each phase to named MITRE ATT&CK techniques and embedded technique-specific evidence in injects.
Structural completeness needed formal metrics and exercise-control mechanisms.	Added exercise staff roles, controller rules, evaluator guidance, observer scorecards, and a 1–5 scoring rubric.
Realism needed concrete environment and operational detail.	Added platform architecture, control dependencies, telemetry sources, payment flows, privileged roles, and exercise notification thresholds.
Training value needed measurable criteria and deeper technical decision points.	Added measurable success criteria, cyber responder decision points, hunt tasks, evidence preservation triggers, and recovery gates.
Coherence needed clearer evidence versus assumptions.	Each inject separates confirmed facts, assumptions/unknowns, expected decisions, and facilitator notes.

2. Exercise Objectives and Success Criteria

The objectives are designed for executive, operational, technical, compliance, legal, and crisis-management audiences. The facilitator should measure not only whether participants identify the correct answer, but also whether they apply governance, preserve evidence, make timely risk decisions, and document the basis for those decisions.

- Detect and validate abnormal AML/sanctions screening outcomes, especially zero-alert or near-zero-alert conditions during normal transaction throughput.
- Determine whether the event is an operational anomaly, cyber incident, data integrity event, compliance breach, or a combination of these categories.
- Establish incident governance quickly, including crisis leadership, SOC/IR, compliance, payment operations, legal, communications, audit, and senior management.
- Decide when to hold, queue, manually screen, or pause payment classes, corridors, or customer segments.
- Define a defensible lookback population, prove its completeness, and launch retrospective screening/replay.
- Preserve forensic and audit evidence without compromising service restoration.
- Build a regulator-ready fact pattern containing confirmed facts, unknowns, impact, actions taken, and next-update timing.
- Define recovery criteria before resuming normal processing, including integrity validation, rule restoration, monitoring, backlog management, and executive approval.

- Identify long-term improvements for fail-safe behavior, integrity monitoring, privileged access, change control, alert baselining, and compliance contingency planning.

2.1 Measurable Exercise Success Criteria

Criterion	Target behavior to observe	Evidence of success
Detection	Participants treat zero alerts during normal throughput as a possible silent control failure.	Named owner validates dashboard, API, rule engine, watchlist feed, and transaction outcomes within the first inject.
Classification	Participants classify the event as a potential cyber integrity and compliance incident, not simply a platform availability issue.	Incident severity is set with rationale and reviewed as facts evolve.
Governance	Participants activate the right crisis/incident structure without bypassing SOC, compliance, or legal responsibilities.	Clear decision owner, scribe, and communications owner are assigned.
Containment	Participants adopt risk-based holds, queues, and manual review rather than continuing all payments by default.	Payment classes/corridors are segmented and approved controls are documented.
Lookback	Participants define the affected population and completeness proof.	Lookback window, transaction sources, replay method, and exception handling are documented.
Technical response	SOC and application teams preserve logs, protect evidence, and investigate a plausible adversary chain.	Hunt plan covers valid accounts, admin changes, telemetry impairment, lateral movement, and stored data manipulation.
Regulatory readiness	Compliance/legal prepare transparent, controlled messaging and escalation criteria.	Known facts, unknowns, actions, and next update timing are available within the scenario window.
Recovery	Participants require objective evidence before declaring normal operations restored.	Rule checksums, watchlist validation, canary screening, replay results, monitoring, and approvals are recorded.

3. Scope

3.1 In Scope

- AML and sanctions screening platform, rule engine, watchlist/reference data, alert generation, case management, and screening outcomes.
- Payment operations and transaction flows, including release/hold/queue decisions and transaction backlogs.
- Financial crime, compliance operations, sanctions advisory, legal, privacy, internal audit, communications, business continuity, and crisis management.
- SOC, cyber incident response, application support, IAM/PAM, database administration, logging, monitoring, and change/release management.
- Regulatory escalation, notification assessment, supervisory update preparation, and post-incident commitments.
- Retrospective transaction screening, evidence preservation, and recovery decisioning.

3.2 Out of Scope

- Live changes to production systems during the exercise.
- Detailed malware reverse engineering or exploit development.
- Jurisdiction-specific legal advice or final regulatory notification determination.
- Vendor contract negotiation, disciplinary proceedings, or external press release drafting beyond high-level messaging principles.
- Implementation-level recovery steps that require real infrastructure access.

3.3 Exercise Assumptions

- The institution is a generic financial services organization with international payment and compliance obligations.
- Regulatory thresholds in this document are exercise triggers for discussion; legal and compliance leadership decide actual notification obligations.
- Participants respond using existing roles, responsibilities, procedures, and escalation paths.
- The adversary pathway is a plausible fictional enrichment added to strengthen cyber training value; participants should still maintain investigative uncertainty until evidence is confirmed.
- No simulated operational decision should be executed in real production unless separately authorized outside the exercise.

4. Intended Participants

Audience	Representative roles	Primary exercise focus
Executive / Crisis	Business leadership, crisis-management lead, CISO/CIO, chief compliance officer/MLRO equivalent, general counsel, communications lead.	Risk appetite, escalation, regulator/board posture, payment continuity decisions, public confidence, recovery authorization.
Compliance / Legal	Financial crime, sanctions advisory, AML operations, legal, privacy, regulatory affairs, internal audit.	Control failure assessment, regulatory notification, lookback completeness, suspicious/prohibited transaction handling, defensible decision logs.
Operations / Business	Payment operations, transaction services, client service, business continuity, customer/counterparty management.	Hold/queue/manual-review decisions, backlogs, service impacts, prioritization, customer commitments.
Technical / Cyber	SOC, incident response, threat hunting, app support, DBAs, infrastructure, IAM/PAM, logging/SIEM, change/release management.	Evidence preservation, root cause analysis, adversary path validation, integrity checks, telemetry restoration, recovery gates.

5. Exercise Structure and Rules of Engagement

- Recommended duration: 90 minutes for core injects, plus 30 minutes for scoring and debrief.
- Format: Facilitated discussion-based tabletop with sequential injects and time-boxed debrief periods.
- Timeline convention: Relative exercise time begins at discovery of the abnormal alert condition.
- Real-world incidents take priority.
- There are no right or wrong answers; the goal is to surface strengths, gaps, and decision criteria.
- Participants should not debate away the scenario. They should act as if the information is plausible and incomplete.
- Participants should distinguish confirmed evidence, assumptions, working hypotheses, and decisions.
- All major decisions should include decision owner, rationale, time, risk accepted, and next review point.

5.1 Exercise-Control Roles

Role	Responsibilities
Exercise Director	Owns exercise objectives, pacing, scope discipline, and final debrief decisions.
Lead Facilitator	Introduces injects, manages discussion, ensures all audience groups contribute, and prevents scenario drift.
Inject Controller	Releases injects, clarifications, and optional artifacts only when the exercise director approves.
Technical Controller	Answers technical clarifying questions consistently and prevents over-specific implementation debates.
Compliance/Legal Controller	Clarifies regulatory, legal, and financial crime assumptions without giving actual legal advice.
Scribe	Captures decisions, assumptions, action items, owners, timestamps, and open questions.
Evaluators / Observers	Score performance using the rubric, record evidence, and identify improvement themes.

5.2 Control Coordination Mechanisms

- Use a single exercise clock and announce each inject time clearly.
- When participants request more data, controllers should provide only information that is available at that scenario stage.
- Controllers should challenge unsupported certainty. For example: “What evidence confirms this?” or “What assumption are you relying on?”
- The scribe should maintain a decision log, an assumption log, an action register, and a parking lot for unresolved questions.
- Observers should score observable behaviors, not personal performance.

6. Scenario Background

The bank relies on an AML and sanctions screening platform to apply watchlists, interdiction rules, customer-risk logic, and transaction monitoring controls to payment and customer activity. The platform is a critical compliance control because it determines whether transactions may proceed, are queued for review, or are blocked.

During a normal business period, compliance operations observes that sanctions and AML alert volumes have dropped to zero while payment throughput remains normal. Initial system health dashboards show the screening platform as available, creating a classic integrity problem: the service may be online, but its control output may be invalid.

As the scenario progresses, technical evidence suggests that screening logic and/or reference data were altered to fail open. The organization must determine how to contain regulatory exposure, preserve evidence, manage payment operations, notify stakeholders, perform retrospective screening, and restore confidence in the control environment.

7. Environment and Asset Overview

7.1 Simplified Platform Architecture

Layer	Representative components	Failure or control dependency
Payment intake	SWIFT/wire gateways, domestic payment channels, online banking, treasury systems, batch files.	Transactions must be uniquely identifiable and replayable; high-risk corridors require prioritization.
Payment hub / orchestration	Payment routing, enrichment, payment status store, release/hold queue, operational dashboard.	Depends on screening API result, hold/block codes, and queue integrity.
AML/sanctions screening API	Screening service, API gateway, transaction screening adapter, customer screening adapter.	API success must not be treated as proof of screening success; response must include valid screening decision and trace ID.
Rule engine and reference data	Sanctions lists, politically exposed person/watchlist data, AML scenarios, interdiction rules, customer-risk data, rule versions.	Integrity depends on approved change control, rule checksums, watchlist-feed reconciliation, and privileged access controls.
Case management	Alert queue, analyst workflow, escalation paths, evidence notes, case outcomes.	Zero alerts during normal throughput must trigger independent validation and escalation.
Control telemetry	SIEM, application logs, database audit logs, PAM logs, EDR, change-management records, privileged session recordings, rule-hash validation.	Telemetry must be complete enough to determine who changed what, when, from where, through which tool, and with what result.

7.2 Logical Payment and Screening Flow

Step	Normal flow	Exercise failure mode
1	Payment enters payment hub and is enriched with customer, counterparty, geography, amount, and corridor attributes.	Payment attributes appear complete; volume remains normal.
2	Payment hub calls screening API and receives a decision: allow, hold, block, or escalate.	API returns technical success but screening decision is empty, default allow, or lacks a reliable screening trace ID.
3	Rule engine checks watchlists, AML scenarios, and exceptions, then creates an alert/case if required.	Rule logic or reference-data lookup fails open; expected alerts are not created.
4	Payment operations acts on screening outcome and documented exceptions.	Operations cannot distinguish properly screened transactions from unscreened transactions without lookback/replay.
5	Monitoring reconciles transaction volume, alert volume, rule versions, watchlist versions, and system health.	Availability dashboards remain green while integrity baselines, alert ratios, and rule-hash checks indicate failure.

7.3 Detection Telemetry to Use During the Exercise

- Alert-volume baselines by product, corridor, geography, customer risk rating, and time of day.
- Transaction volume and value by payment rail, including release, hold, queue, and rejection rates.
- Screening API request/response logs, screening trace IDs, error codes, and latency distributions.
- Rule and watchlist checksums, version history, deployment packages, and approved change tickets.
- Privileged access logs: PAM checkout, admin console login, service account token use, MFA events, source IP, session recording, and access approval.
- Database audit logs for insert/update/delete actions on rules, reference data, suppression tables, exception tables, and configuration flags.
- SIEM ingestion health, log-forwarding status, EDR alerts, network egress telemetry, and jump-server access records.
- Case-management queue metrics: alert creation rate, analyst assignment, escalations, closures, and reopened cases.

7.4 Exercise Notification and Escalation Triggers

Trigger	Exercise threshold	Expected escalation
Potential unscreened transactions	Any confirmed transaction with no valid screening trace ID.	Financial crime/compliance lead, payment operations lead, legal, SOC, application owner.
Sustained alert collapse	Zero or near-zero alert volume for more than 30 minutes during normal throughput, or material deviation from expected baseline.	Incident manager, compliance operations, application support, SOC, business owner.
Critical rule/reference data integrity issue	Checksum mismatch, unauthorized change, unapproved deployment, or fail-open configuration on high-risk rules.	Crisis management consideration; privileged access freeze; technical evidence preservation.
High-risk payments impacted	Payments involving high-risk corridors, sanctioned-risk jurisdictions, politically exposed persons, high-value wires, or correspondent banking flows.	Risk-based hold/queue/manual screening decision by authorized business and compliance owners.
Regulator or supervisory contact	Formal or informal inquiry, media interest, or obligation assessment triggered by legal/compliance.	Regulatory affairs, legal, executive leadership, communications.
Operational resilience impact	Backlog threatens critical service level, market commitments, customer harm, or recovery-time objective.	Crisis management and business continuity leadership.

8. Scenario Narrative

The exercise starts when compliance operations notices that AML and sanctions alerts have unexpectedly fallen to zero, despite payment throughput staying within the normal range. Participants initially know only that the alert collapse is abnormal. They do not yet know whether the issue is a dashboard failure, operational defect, deployment error, malicious tampering, or a broader cyber incident.

The enhanced storyline adds a realistic adversary hypothesis: a threat actor has obtained valid credentials and used remote access and administrative tooling to modify screening rules, suppress or degrade supporting telemetry, and cause the platform to fail open. The scenario intentionally introduces evidence gradually so participants must maintain investigative discipline while making urgent business and compliance decisions.

The most difficult decisions involve determining whether payments may continue, how to implement credible compensating controls, how to prove the completeness of the affected transaction population, what to tell regulators, and what evidence is required before normal processing resumes.

9. End-to-End Adversary Pathway

Exercise note: The original scenario identified “tamper with compliance screening data or rules to fail open” as the core attack pattern. This enhanced version adds a plausible adversary chain for technical training. The chain is not revealed all at once; it is progressively introduced through injects.

Stage	Plausible adversary behavior	ATT&CK alignment	Evidence participants should seek
1. Initial access	Compromised credentials for a privileged support or rules-administration user are used through remote access.	Valid Accounts (T1078); External Remote Services (T1133); Phishing (T1566) if credential theft is later confirmed.	VPN/MFA logs, source IP, impossible travel, PAM checkout records, helpdesk reset history.
2. Credential use / privilege	The account has or gains rights to the AML rule-administration console and deployment repository.	Valid Accounts (T1078); Account Manipulation (T1098).	Group membership changes, token issuance, role assignments, approval records, privileged session logs.

Stage	Plausible adversary behavior	ATT&CK alignment	Evidence participants should seek
3. Discovery	Actor enumerates rule repositories, admin groups, screening servers, watchlist paths, and service accounts.	Account Discovery (T1087); Network Service Discovery (T1046); System Information Discovery (T1082).	Directory queries, admin console browsing, unusual API calls, command execution telemetry.
4. Execution	Actor uses legitimate scripts or admin functions to deploy a modified rule package and configuration flag.	Command and Scripting Interpreter (T1059); administrative tooling.	Change scripts, deployment logs, CI/CD records, script execution, file hashes, account used.
5. Persistence	Actor attempts to keep access by adding a backup role, token, or service credential.	Account Manipulation (T1098); Valid Accounts (T1078).	New tokens, unexpected service account keys, dormant admin accounts, group changes.
6. Defense impairment	Actor modifies logging, alerting, or pipeline behavior so the service looks healthy while control outcomes are invalid.	Disable or Modify Tools (T1685); Disable or Modify Cloud Log (T1685.002) or Windows Event Log (T1685.001).	Log gaps, SIEM ingestion interruptions, telemetry routing changes, rule-error metrics suppressed.
7. Lateral movement	Actor uses remote services or a jump server to reach the rule database, watchlist store, or admin console.	Remote Services (T1021).	Jump-host sessions, server logons, RDP/SSH/WinRM/management API telemetry.
8. Command and control / transfer	A small tool or script is transferred or retrieved to compare rule versions and apply changes.	Ingress Tool Transfer (T1105); Application Layer Protocol (T1071) if C2 is observed.	Egress logs, proxy logs, file downloads, uncommon user-agent or destination patterns.
9. Impact	Screening logic, watchlist reference data, or fail-open behavior is changed so transactions proceed without expected checks.	Data Manipulation (T1565); Stored Data Manipulation (T1565.001).	Rule checksum mismatch, database changes, missing screening trace IDs, zero alerts, successful canary bypass.

10. Evidence Discipline: Confirmed Facts vs Assumptions

At every stage, participants should separate confirmed evidence from assumptions and working hypotheses. This is central to the exercise because the organization must make decisions before the investigation is complete.

Scenario stage	Confirmed evidence	Assumptions / unknowns to challenge
T+0	Alert volume is zero or near zero; transaction throughput appears normal; no maintenance window is known.	Whether the alert dashboard is broken; whether screening is still executing; whether any transaction is unscreened.
T+30 min	Canary or sampled transactions lack expected screening trace IDs; rule-engine error rate or null decision rate is abnormal.	Whether issue is rule logic, data feed, API, deployment, or malicious tampering.
T+2 hours	Some transactions may have proceeded without valid screening evidence; lookback window is not final.	Exact exposure duration; whether high-risk corridors were affected; whether regulator notification threshold is met.
T+1 business day	Rule checksum mismatch and privileged activity are identified around the alert collapse.	Whether the change was unauthorized, privileged misuse, compromised credentials, or defective deployment.
T+2 business days	Restored rules pass initial validation; retrospective screening identifies exceptions requiring review.	Whether all affected transactions have been captured; whether additional persistence remains; whether normal operations can resume.
Post-incident	Decision logs, regulator updates, restoration evidence, and remediation commitments exist.	Whether longer-term control improvements are sufficient and funded.

11. Master Timeline and Inject Summary

Inject	Exercise time	Main development	Primary decisions
1	T+0	Alert volume collapses during normal payment throughput.	Validate control failure; open incident; assign severity; preserve initial evidence.
2	T+30 to T+60 min	Control validation shows inconsistent or missing screening trace IDs.	Decide immediate compensating controls; separate dashboard issue from true screening failure.
3	T+2 to T+4 hours	Potential unscreened transactions and regulator/senior management pressure.	Hold/queue/manual-review decisions; lookback window; regulator-ready fact pattern.
4	T+1 business day	Root-cause uncertainty deepens; privileged activity and rule mismatch emerge.	Cyber escalation; preserve evidence; hunt adversary path; freeze privileged changes; manage backlog.
5	T+2 business days	Containment and retrospective screening results become available.	Recovery gates; formal resumption approval; exception remediation; regulator update.
6	T+10 business days	Post-incident obligations, lessons learned, and control uplift.	After-action plan; control owner commitments; scoring; lessons learned.

12. Detailed Injects and Facilitation Guide

Inject 1 — Abnormal alert volume collapse

Time: T+0

Inject statement: Compliance operations notices that AML and sanctions alert volumes have dropped to zero or near zero while payment throughput remains within normal range.

Confirmed facts available to participants

- Transaction volumes are within expected range for the business period.
- AML and sanctions alerts have fallen to zero or near zero unexpectedly.
- No approved maintenance window, rule promotion, or watchlist update freeze is known.
- Availability dashboards show the screening platform as online.

Assumptions and unknowns

- It is not yet known whether the issue is dashboard telemetry, screening API, rule logic, watchlist data, deployment error, or malicious tampering.
- It is not yet confirmed whether any transaction bypassed screening.
- The affected products, geographies, payment rails, and customer segments are not yet known.

Facilitator prompts

- Who is accountable for validating that screening is functioning end-to-end?
- What is the immediate communication path between compliance operations, payment operations, application support, SOC, and incident management?
- What checks distinguish an availability issue from an integrity failure?
- At what point should this become a compliance incident, cyber incident, operational resilience incident, or crisis-management event?
- What payment categories should be prioritized for validation first?

Expected actions

- Open an incident record and appoint an incident manager and scribe.

- Compare alert volume against expected baselines by product, corridor, and customer-risk segment.
- Validate recent rule, watchlist, configuration, and code changes.
- Preserve dashboards, logs, rule versions, and initial anomaly evidence.
- Notify SOC and application support that the event may involve a silent integrity failure.
- Start a decision log and assumption log.

Technical decision points / hunt tasks

- Run a canary/synthetic transaction through the screening path where permitted by procedure.
- Confirm whether API responses include valid decision codes and screening trace IDs.
- Check SIEM ingestion health, application log continuity, and rule-engine error metrics.
- Identify recent privileged sessions and change tickets affecting rules, watchlists, or fail-open configuration.

Facilitator notes

- Push participants away from relying solely on green system-health dashboards.
- Ask participants whether their procedures define alert-volume collapse as an integrity alert.
- Challenge unsupported assertions that “no alerts means no risk.”

Evaluator observations

- Did participants identify integrity risk within the first discussion period?
- Was an incident manager and scribe assigned?
- Did participants preserve evidence before making changes?

Inject 2 — Control validation fails

Time: T+30 to T+60 minutes

Inject statement: A sampled set of transactions shows normal payment status but missing or invalid screening trace IDs. Application support reports that the screening API is returning success responses even when rule-engine checks are incomplete.

Confirmed facts available to participants

- Sampled payments include “released” or “ready to release” status.
- Some sampled transactions do not show a valid screening trace ID or expected rule-evaluation record.
- The screening API is responding successfully from a technical availability perspective.
- No approved emergency rule change has been located so far.

Assumptions and unknowns

- The completeness of the sample is not known.
- It is unclear whether the API, rule engine, reference data, or exception handling is responsible.
- It is unclear whether the failure is malicious or caused by a defective deployment.
- It is unclear whether high-risk customers or corridors were affected.

Facilitator prompts

- What is the minimum evidence required to declare a control failure?
- Which transactions should be held immediately while validation continues?

- Who approves temporary compensating controls and how are they documented?
- Should the incident severity be raised based on potential unscreened payments?
- What must be communicated to senior management at this stage?

Expected actions

- Declare a potential AML/sanctions screening integrity failure.
- Segment payment flows by risk: high-value, high-risk corridors, sanctions exposure, correspondent banking, customer-risk rating, and time criticality.
- Implement temporary holds, queues, or manual screening for high-risk activity.
- Begin defining a provisional lookback window from last known good rule version to current time.
- Engage compliance leadership, legal, payment operations leadership, SOC/IR, and crisis management as required.
- Prepare a factual status update with confirmed facts, unknowns, actions, decisions, and next update time.

Technical decision points / hunt tasks

- Compare production rule checksums to last approved baseline.
- Review recent deployments, database updates, and admin-console actions.
- Check whether the system has a fail-open path for rule-engine errors and whether it was triggered.
- Preserve API logs, database audit logs, rule packages, application logs, PAM logs, and SIEM alerts.

Facilitator notes

- Push participants to define credible compensating controls, not generic “manual review.”
- Ask whether operations can prove which transactions were actually screened.
- Test whether SOC is appropriately engaged as an investigator, not as the owner of payment or regulatory decisions.

Evaluator observations

- Did participants set risk-based payment controls rather than all-or-nothing decisions?
- Did they establish a lookback methodology early?
- Did they avoid premature external messaging before legal/compliance review?

Inject 3 — Transaction lookback and regulator pressure

Time: T+2 to T+4 hours

Inject statement: Preliminary analysis indicates that some transactions may have proceeded without proper screening. Executive leadership asks whether payments should continue, and compliance receives a supervisory inquiry asking whether a critical compliance control is operating normally.

Confirmed facts available to participants

- The duration of exposure is not yet confirmed.
- A provisional lookback window has been proposed but not validated.
- High-risk payment classes may be affected, but the population is not complete.
- A supervisory contact has asked for an update, but the organization has not made a formal notification decision.
- Business lines are reporting pressure from customers and counterparties due to held or delayed payments.

Assumptions and unknowns

- The number and value of unscreened transactions is still unknown.

- It is unknown whether any prohibited party or suspicious transaction was processed.
- It is unknown whether the root cause is malicious tampering, deployment error, privileged misuse, or data corruption.
- Manual screening capacity may not be sufficient for all queued transactions.

Facilitator prompts

- What criteria justify halting all payments versus selected classes, corridors, or customers?
- Who has authority to pause payments, accept residual risk, and approve compensating controls?
- How will the organization prove the completeness of the affected population?
- What can be said to regulators now without overstating or understating the situation?
- How will customer/counterparty communications be controlled?
- What evidence is needed before normal processing resumes?

Expected actions

- Confirm decision authority for payment holds, manual screening, and crisis escalation.
- Approve risk-based payment triage: highest sanctions exposure first; time-critical but low-risk transactions may follow documented exception handling.
- Create a regulator-ready fact pattern: known facts, unknowns, immediate actions, risk controls, impact estimates, and next update timing.
- Launch retrospective screening/replay planning with data owners, application support, and compliance operations.
- Capture all decisions, risk acceptances, manual overrides, and approvals.
- Prepare internal talking points for operations and client-facing teams.

Technical decision points / hunt tasks

- Design the lookback query using multiple sources: payment hub, screening API logs, case-management logs, and database audit logs.
- Identify the last known good rule/watchlist state and first suspicious change.
- Confirm whether log gaps exist and identify alternate evidence sources.
- Begin threat hunt for valid account abuse, remote access, rule repository access, and data manipulation.

Facilitator notes

- Introduce business pressure. Ask what level of disruption is acceptable to protect compliance integrity.
- Push for evidence-based external communications. "We are investigating" may be safer than "no impact."
- Ask whether the crisis cell understands what SOC can decide versus what business/compliance/legal must decide.

Evaluator observations

- Did participants define a complete lookback approach?
- Was the regulator-ready fact pattern credible and appropriately caveated?
- Were payment decisions explicitly risk-based and documented?

Inject 4 — Root cause uncertainty deepens

Time: T+1 business day

Inject statement: Technical review identifies a rule checksum mismatch and administrative activity shortly before the alert collapse. A privileged account accessed the rule-administration console from an unusual remote-access session. It remains

unclear whether the account owner acted maliciously, credentials were compromised, or a defective deployment was used.

Confirmed facts available to participants

- Rule and/or reference-data integrity cannot yet be trusted.
- Privileged access activity occurred shortly before alerts collapsed.
- Log-forwarding or alerting telemetry shows a gap or configuration change around the same period.
- Manual screening capacity is limited and backlogs are growing.
- Several high-value or time-sensitive transactions require urgent decisioning.

Assumptions and unknowns

- It is not confirmed whether the privileged user was the actual actor.
- It is not confirmed whether additional persistence exists.
- It is not confirmed whether data was exfiltrated.
- It is not confirmed whether all altered rules and reference data have been identified.

Facilitator prompts

- What evidence would justify escalating from compliance incident to confirmed cyber incident?
- How do you balance containment, forensic preservation, and restoration urgency?
- Should privileged access to the platform be frozen, restricted, or monitored under emergency procedure?
- What actions are appropriate regarding the account owner while preserving fairness, legal defensibility, and evidence?
- How are backlog and customer-impact decisions approved and documented?

Expected actions

- Escalate severity if thresholds are met and activate cyber incident response governance.
- Restrict or freeze privileged changes to the platform unless approved through emergency control.
- Disable or rotate suspected credentials, preserve session records, and review MFA and PAM evidence.
- Validate rule and watchlist integrity against trusted baselines.
- Continue risk-based manual screening and backlog triage.
- Coordinate technical investigation findings with compliance validation and legal review.

Technical decision points / hunt tasks

- Hunt for T1078 valid account abuse across VPN, PAM, admin console, and database access.
- Hunt for T1098 account or role manipulation, new tokens, emergency access assignments, or service-account changes.
- Hunt for T1685 defense impairment: log forwarding changes, missing logs, disabled sensors, alert suppression, or SIEM ingestion gaps.
- Hunt for T1021 lateral movement from jump servers to rule databases or application hosts.
- Hunt for T1565/T1565.001 stored data manipulation in rule tables, reference data, exception lists, and fail-open configuration.

Facilitator notes

- Maintain uncertainty. Participants should not assume malicious insider or external actor without evidence.
- Push participants to describe what can be restored now versus what must remain preserved for investigation.
- Ask how legal, HR, and security coordinate if a named privileged user is implicated.

Evaluator observations

- Did participants design a technique-informed hunt plan?
- Did they avoid contaminating evidence during recovery?
- Did they make clear ownership distinctions between SOC, crisis management, compliance, and business operations?

Inject 5 — Recovery decision and retrospective screening results

Time: T+2 business days

Inject statement: The organization has restored the rule set from a trusted baseline, revalidated watchlist sources, and replayed the provisional lookback population. Retrospective screening identifies a subset of transactions requiring escalated review. Regulators expect a timely update and remediation commitments.

Confirmed facts available to participants

- Restored controls pass initial validation using sample transactions and rule/version checks.
- The lookback population has been reconstructed across the payment hub, screening logs, and case-management data.
- Some transactions require escalated AML/sanctions review, but there is no final determination yet that a prohibited transaction was processed.
- Regulators expect updates on impact, root cause, containment, customer impact, and remediation.
- Operations wants to resume normal automation to reduce backlog.

Assumptions and unknowns

- The completeness of the lookback requires formal sign-off.
- The root cause may not be fully proven.
- Residual persistence or additional unauthorized changes may still be possible.
- Regulator expectations may differ by jurisdiction.

Facilitator prompts

- What evidence is required before declaring recovery?
- Who approves resumption of normal processing?
- What residual risk is acceptable and who accepts it?
- What should be communicated to regulators, senior management, board committees, and internal teams?
- How are exceptions from retrospective screening tracked to closure?

Expected actions

- Require a formal recovery gate: rule checksum validation, watchlist validation, canary tests, negative/positive test cases, monitoring restoration, and privileged access review.
- Obtain documented approvals from business, compliance, technology, cyber, and legal as required.
- Complete retrospective screening and exception disposition with named owners and due dates.
- Prepare regulator and executive update, including root-cause status, impact assessment, corrective actions, and next milestones.
- Transition from crisis response to remediation governance.

Technical decision points / hunt tasks

- Confirm no unauthorized rules or exception tables remain.

- Validate log-forwarding continuity and alert-volume baselines after restoration.
- Review EDR/network telemetry for continued suspicious access.
- Confirm credential rotation, token revocation, account-rights review, and monitored emergency access.
- Define monitoring thresholds for recurrence.

Facilitator notes

- Push participants to avoid “system is back online” as recovery evidence.
- Ask if all stakeholders agree on the recovery definition.
- Test how unresolved root-cause uncertainty affects communications and risk acceptance.

Evaluator observations

- Were recovery gates objective and testable?
- Was residual risk formally accepted?
- Were regulator updates accurate, controlled, and actionable?

Inject 6 — Post-incident obligations and control uplift

Time: T+10 business days

Inject statement: The immediate incident is closed, but leadership requires a post-incident report, formal after-action plan, control remediation roadmap, and evidence that improvement actions are tracked to completion.

Confirmed facts available to participants

- Incident response activities have ended or transitioned to remediation.
- Regulatory follow-up remains open.
- Some remediation items require funding, ownership, or prioritization.
- Internal audit is requesting evidence of decision-making and control restoration.

Assumptions and unknowns

- Whether all root-cause analysis is final.
- Whether all regulatory expectations are closed.
- Whether control improvements will be implemented before the next similar event.

Facilitator prompts

- What should the post-incident report include?
- Which corrective actions are mandatory versus optional?
- How will the organization prove that fail-open conditions are prevented or detected sooner?
- Who owns remediation governance and how is progress reported?
- What should be retested in the next tabletop or technical simulation?

Expected actions

- Produce an after-action report with chronology, impact, decisions, root cause, control gaps, remediation, and open issues.
- Assign owners and due dates for each improvement action.
- Define control testing for rule integrity, watchlist integrity, alert baselines, fail-safe behavior, lookback/replay, and regulator communications.

- Review privileged access, change management, emergency access, and monitoring over compliance platforms.
- Schedule a follow-up exercise or technical control test.

Technical decision points / hunt tasks

- Implement automated rule-hash validation and alert-volume anomaly detection.
- Review fail-open/fail-closed configuration and document exception handling.
- Test replay procedures using a controlled transaction population.
- Validate detections mapped to ATT&CK techniques used in the scenario.

Facilitator notes

- Make the debrief concrete. Every gap should become an action with owner and due date.
- Ask participants what evidence would satisfy audit and regulators after remediation.

Evaluator observations

- Did the group produce a prioritized action plan?
- Were owners and due dates assigned?
- Were technical and governance improvements linked to observed gaps?

13. Key Decision Points

1. Is the event an operational anomaly, data integrity incident, cyber incident, compliance breach, operational resilience event, or all of these?
2. Should payments continue, queue, be manually screened, or stop entirely? Which payment classes are included?
3. What compensating controls are acceptable, credible, and sustainable while root cause remains under investigation?
4. What is the provisional lookback window, and what evidence proves completeness?
5. When should legal and compliance leadership formally notify or update regulators?
6. What information may be shared with customers, counterparties, internal teams, and senior management before root cause is confirmed?
7. Which privileged accounts, sessions, tokens, and service accounts should be restricted or rotated?
8. What evidence is required before resuming normal automation?
9. How should residual risk and unresolved uncertainty be documented?
10. What longer-term control improvements are mandatory?

14. Discussion Questions by Audience

Audience	Discussion questions
Executive / crisis management	What is the worst credible outcome? Who owns payment risk acceptance? What must be escalated to the board? How much disruption is acceptable to protect compliance integrity? What is the external posture if regulators or media ask questions?
Compliance / legal	Does this meet internal notification thresholds? What records must be preserved? How is lookback completeness proven? What customer, correspondent, or supervisory disclosures might be needed? How are suspicious/prohibited transactions escalated?
Operations / business	Which payment flows are most time-sensitive or highest risk? What manual workarounds exist and what risk do they create? How are backlogs prioritized? What customer commitments are at risk? Who approves exceptions?
Technical / cyber	What evidence supports valid account abuse, unauthorized change, telemetry impairment, or stored data manipulation? What logs are authoritative? What hunt hypotheses should be tested? What controls must be validated before recovery?
Communications / stakeholder management	What can be communicated internally without causing confusion? What language avoids premature conclusions? Who approves external messaging? What cadence is needed for impacted teams?
Internal audit / risk	Were decisions documented? Are control gaps linked to actions? Is remediation tracked? Is evidence sufficient to support defensibility under supervisory review?

15. Technical and Business Impact Assessment

Impact area	Potential effect	Questions to test
Technical integrity	Loss of trust in screening outcomes, rule sets, watchlists, reference data, alert pipelines, and audit logs.	Can the organization independently verify rule and data integrity? Are alternate logs available if primary telemetry is impaired?
Cyber response	Potential credential misuse, unauthorized privileged activity, persistence, telemetry suppression, or lateral movement.	Can SOC rapidly correlate PAM, VPN, SIEM, EDR, database, and application logs?
Compliance	Possible processing of transactions without AML/sanctions checks; increased regulatory exposure.	Can compliance prove whether prohibited or suspicious activity occurred?
Operations	Payment holds, queues, delays, manual screening burden, and service-level breaches.	What manual capacity exists? Which transactions are prioritized? Who accepts delays?
Customers / counterparties	Potential delays, uncertainty, complaints, or loss of trust.	What customer messaging is accurate and approved?
Regulatory / legal	Potential notification, supervisory scrutiny, enforcement risk, and post-incident commitments.	What facts are known, what remains unknown, and what is the update cadence?
Reputation	Perceived failure of critical controls if incident becomes public.	Who owns external communications and reputational risk monitoring?
Audit / assurance	Need for defensible records, decision logs, and evidence of recovery.	Are all key decisions timestamped, approved, and linked to evidence?

16. Communications and Regulatory Considerations

The exercise should not ask participants to provide definitive legal advice. Instead, it should test whether the organization can quickly assemble a defensible notification assessment and determine who has authority to communicate externally.

16.1 Regulator-Ready Fact Pattern

- Incident summary: what happened, when detected, and why it matters to critical AML/sanctions controls.
- Confirmed facts: alert collapse, screening trace anomalies, rule or data integrity findings, impacted systems, current status.
- Unknowns: exposure duration, affected transaction population, root cause, malicious intent, and final transaction outcomes.

- Immediate actions: incident activation, evidence preservation, risk-based payment holds, manual screening, lookback/replay, privileged access restrictions.
- Impact assessment: transaction counts/value ranges, high-risk corridors, customer impact, backlog, and exception review status.
- Governance: decision owners, crisis structure, legal/compliance review, and next update timing.
- Remediation commitments: restoration validation, long-term monitoring, fail-safe design review, privileged access review, and control testing.

16.2 Messaging Principles

- Avoid asserting that no breach or no regulatory impact exists until evidence supports that conclusion.
- Avoid attributing the event to a threat actor, insider, vendor, or deployment failure before root cause is confirmed.
- Use consistent language for “control integrity issue,” “potential unscreened transactions,” “under investigation,” and “risk-based compensating controls.”
- Provide internal teams with controlled scripts so client-facing staff do not speculate.
- Document the legal/compliance approval path for all external communications.

17. Roles and Responsibilities Matrix

Activity	Accountable	Consulted / supporting
Incident severity and governance activation	Incident manager / crisis lead	SOC, compliance, app owner, legal, business owner
Payment hold/queue/manual-screening decision	Payment operations executive + compliance lead	Legal, business lines, crisis lead, risk, customer operations
Cyber investigation and threat hunting	SOC/IR lead	App support, IAM/PAM, DBAs, infrastructure, threat intel, legal
Rule/watchlist integrity validation	Application owner + compliance control owner	Change management, DBAs, vendor/support, SOC
Lookback population and retrospective screening	Compliance operations / financial crime lead	Payment data owner, app support, analytics, legal, audit
Regulatory notification assessment	Legal/compliance leadership	Regulatory affairs, crisis lead, business owner, communications
Internal and external communications	Communications lead + legal/compliance approval	Crisis lead, business lines, customer service
Recovery approval	Business owner + compliance + technology leadership	SOC/IR, legal, audit, crisis management
After-action tracking	Risk/control owner	Internal audit, technology, compliance, business continuity, security governance

18. Facilitator Guide

18.1 Desired Behaviors to Observe

- Early recognition that an online system can still produce invalid compliance outcomes.
- Rapid cross-functional coordination without confusing SOC ownership with business/compliance decision authority.
- Clear decision logging, including assumptions, evidence, risk acceptance, and approvals.
- Risk-based containment balancing regulatory exposure and business disruption.
- Credible compensating controls that could withstand supervisory scrutiny.

- Technical investigation that follows evidence and maintains multiple hypotheses.
- Recovery criteria based on objective validation rather than optimism or pressure.
- A debrief that results in specific owners, due dates, and control tests.

18.2 Common Gaps to Test

- Overreliance on availability dashboards or vendor/application health indicators.
- Unclear authority to pause payments or invoke manual screening.
- No tested procedure for lookback/replay of unscreened transactions.
- Weak evidence preservation and insufficient log sources.
- Insufficient privileged access monitoring for compliance platforms.
- Premature conclusions about root cause or regulatory impact.
- Unclear regulator communication thresholds and approval paths.
- Recovery decisions based on service restoration rather than control assurance.

18.3 Stretch Questions

- What if the affected window began three days earlier than first believed?
- What if only one payment rail or geography is affected?
- What if manual screening volume exceeds staffing capacity within four hours?
- What if a regulator asks for proof that no prohibited transaction was processed?
- What if a privileged user denies the activity and claims account compromise?
- What if primary logs are missing or partially unreliable?
- What if a high-value client demands urgent release of a payment in a high-risk corridor?
- What if media learns the bank has delayed payments due to a compliance-control failure?

19. Evaluation Model and Scoring Rubric

Evaluators should score observable performance using a 1–5 scale. Scores should be supported by notes and examples, not impressions. A score of 3 indicates minimum acceptable performance with gaps; a score of 5 indicates mature, repeatable, and evidence-backed performance.

Score	Definition
1 – Not demonstrated	Participants did not identify or act on the issue, or actions were unsafe, unowned, or unsupported.
2 – Partially demonstrated	Some relevant actions were discussed, but ownership, timing, evidence, or decision criteria were unclear.
3 – Adequate	Minimum viable response demonstrated; key decisions made, but gaps or delays would create risk.
4 – Strong	Response was structured, timely, cross-functional, and mostly evidence-based with minor gaps.
5 – Mature	Response was repeatable, evidence-backed, well-governed, and supported by clear playbooks, metrics, and recovery criteria.

Evaluation domain	Observable indicators	Score
Detection and validation	Alert-volume anomaly recognized; dashboard vs control failure distinguished; canary/sampling validation proposed; baseline used.	1 2 3 4 5

Evaluation domain	Observable indicators	Score
Severity and escalation	Classification reviewed as facts evolve; cyber/compliance/operational resilience thresholds considered; right stakeholders engaged.	1 2 3 4 5
Governance and decision authority	Incident manager, scribe, decision owners, and approval paths identified; crisis cell engaged appropriately.	1 2 3 4 5
Technical investigation	Logs preserved; adversary hypotheses tested; privileged access, telemetry impairment, lateral movement, and data manipulation investigated.	1 2 3 4 5
Payment containment	Risk-based hold/queue/manual screening used; high-risk corridors/customers prioritized; residual risk approved.	1 2 3 4 5
Lookback and retrospective screening	Affected population defined; completeness proof planned; replay process and exception handling documented.	1 2 3 4 5
Regulatory/legal communications	Fact pattern built; unknowns clearly stated; legal/compliance approval path followed; regulator update cadence established.	1 2 3 4 5
Recovery and assurance	Objective recovery gates defined; monitoring restored; rule/watchlist integrity validated; resumption approved with residual-risk statement.	1 2 3 4 5
Documentation and lessons learned	Decision log, action register, assumptions, evidence, owners, and due dates captured; after-action plan produced.	1 2 3 4 5

19.1 Observer Capture Sheet

Item	Notes to capture
Key decisions	Decision, owner, time, rationale, evidence, risk accepted, next review time.
Assumptions	Assumption, owner, validation method, impact if false.
Open questions	Question, owner, due time, dependency.
Strong practices	Specific behaviors, artifacts, or playbooks that worked well.
Gaps	Process, role, technology, data, communication, or authority gaps.
Immediate actions	Actions needed within 24 hours after exercise.
Longer-term actions	Actions requiring funding, governance, control redesign, or policy update.

20. Debrief and Lessons Learned

At the end of the exercise, capture observations under the following headings. Each observation should be converted into an action or accepted risk.

- Detection and validation of silent integrity failures.
- Severity assessment, escalation, and crisis-management activation.
- Decision authority for payment holds, manual screening, and risk acceptance.
- Compensating controls and manual screening capacity.
- Technical investigation, evidence preservation, and ATT&CK-informed hunting.
- Lookback completeness and retrospective screening readiness.
- Regulatory and stakeholder communications.
- Recovery gates and control assurance.
- Privileged access, change management, fail-open prevention, and long-term remediation.

20.1 Suggested After-Action Outputs

- After-action report with timeline, decisions, impacts, root cause status, and lessons learned.
- Action register with owners, due dates, priority, dependencies, and success measures.
- Control improvement plan for integrity monitoring, fail-open prevention, alert-volume anomaly detection, and watchlist/rule validation.
- Privileged access review for compliance platforms, including emergency access and service-account controls.
- Lookback/replay test plan for AML and sanctions screening failures.
- Regulatory notification playbook validation and update.
- Follow-up tabletop or technical simulation focused on rule tampering and recovery validation.

21. Suggested Improvement Actions

Improvement theme	Recommended action	Owner candidates
Integrity monitoring	Implement automated rule and watchlist checksum validation with alerting on drift from approved baselines.	Application owner, compliance control owner, security monitoring
Alert-volume anomaly detection	Create thresholds for zero-alert and low-alert conditions by payment product, corridor, geography, and customer-risk category.	Compliance operations, data analytics, SIEM team
Fail-safe behavior	Review and redesign fail-open pathways so critical screening dependencies fail closed or trigger controlled queueing for high-risk flows.	Architecture, application owner, compliance, operations
Change control	Require dual approval, segregation of duties, and post-change validation for screening rules, reference data, and exception logic.	Change management, compliance, application support
Privileged access	Strengthen PAM, MFA, session recording, just-in-time access, role review, and service-account governance for compliance platforms.	IAM/PAM, SOC, application owner
Lookback readiness	Maintain tested procedures and data mappings for reconstructing affected transaction populations and replaying screening.	Compliance operations, payment data owner, application owner
Regulatory readiness	Pre-stage regulator-ready fact pattern templates and notification decision trees for critical compliance-control failures.	Legal, compliance, regulatory affairs
Exercise program	Run a follow-up technical scenario focused on rule integrity, log impairment, and recovery gates.	Security governance, business continuity, crisis management

22. Source Mapping and Ready-to-Use Opening Script

22.1 Source Mapping

Source element	How reflected in this exercise
Original scenario title	TTX Scenario 10 – Data integrity attack on AML and sanctions screening.
Original scenario core event	Screening logic fails open, allowing transactions to proceed without proper sanctions/AML checks.
Original Inject 1	Alert volumes unexpectedly drop to zero during normal transaction throughput.
Original Inject 2	Retrospective review, payment halt/queue decision, and regulator pressure.
Original optional Inject 3	Rule/reference data integrity issue with uncertainty over malicious tampering, privileged misuse, or defective deployment.
Original optional Inject 4	Recovery decision, retrospective screening results, and post-incident reporting.
Evaluation JSON	Recommendations integrated through adversary chain, ATT&CK mapping, realism details, evidence discipline, success criteria, exercise control, and scoring.

22.2 Opening Script

Today's exercise simulates a cyber-related integrity failure affecting the bank's AML and sanctions screening platform. During a period of normal transaction activity, AML and sanctions alert volumes unexpectedly collapse. The platform appears available, but transactions may not be receiving the expected controls. Your objective is to detect and validate the issue, determine whether it is operational or malicious, contain payment and regulatory exposure, preserve evidence, reconstruct the affected transaction population, communicate appropriately, and define what evidence is required before normal processing resumes. Please respond using your current roles, procedures, escalation paths, and decision authorities.

23. Glossary

Term	Meaning in this exercise
AML	Anti-Money Laundering controls, monitoring, and escalation processes.
Sanctions screening	Controls used to detect and prevent transactions involving prohibited or sanctioned parties, entities, vessels, geographies, or activity.
Fail open	A failure mode in which a control dependency fails but processing continues, potentially without the intended control outcome.
Fail closed	A failure mode in which processing stops or queues when a critical control cannot complete.
Screening trace ID	Unique evidence that a transaction was processed by the screening function and linked to a decision outcome.
Lookback	The process of reconstructing and reviewing transactions processed during a possible control-failure window.
Retrospective screening / replay	Re-running affected transactions through validated screening logic and reference data to identify exceptions.
PAM	Privileged Access Management controls for elevated accounts and administrative sessions.
SIEM	Security Information and Event Management platform used to collect, correlate, and alert on security telemetry.
EDR	Endpoint Detection and Response telemetry and controls on servers or endpoints.
ATT&CK	MITRE ATT&CK knowledge base used to describe adversary behaviors and defensive detection opportunities.

24. MITRE ATT&CK; Mapping

The following mapping reflects the enhanced scenario. Some techniques are confirmed only after later injects; others are investigative hypotheses used to guide defensive questioning. The central scenario impact remains Data Manipulation / Stored Data Manipulation affecting AML and sanctions screening logic or reference data.

Scenario phase	Tactic	Technique / sub-technique	Relevance to scenario
Credential compromise and access	Initial Access / Persistence / Privilege Escalation / Defense Evasion	Valid Accounts (T1078)	A legitimate privileged account or service account is abused to access rule-administration functions without immediately triggering availability alarms.
Remote access	Initial Access / Persistence	External Remote Services (T1133)	Remote access such as VPN or administrative access portal may be used to reach internal compliance systems.
Potential credential theft	Credential Access	OS Credential Dumping (T1003) – conditional	If credential theft is confirmed, responders should check whether account material was harvested and reused for privileged access.
Role or token changes	Persistence / Privilege Escalation	Account Manipulation (T1098)	Unauthorized role, group, token, or service-account changes may preserve or elevate access to compliance tooling.
Administrative scripting	Execution	Command and Scripting Interpreter (T1059)	Legitimate scripts or administrative tooling may be used to apply rule packages or configuration changes.
Account enumeration	Discovery	Account Discovery (T1087)	Adversary may identify privileged accounts, admin groups, or service accounts used by the AML/sanctions platform.
Service enumeration	Discovery	Network Service Discovery (T1046) / System Information Discovery (T1082) – conditional	Adversary may identify reachable application hosts, database services, jump servers, and management endpoints.
Movement to rule store	Lateral Movement	Remote Services (T1021)	Valid credentials may be used from a jump server or admin workstation to access the rule database, admin console, or application servers.
Tool/script transfer	Command and Control	Ingress Tool Transfer (T1105)	A helper script or tool may be transferred to compare rule versions or apply changes; this is a hunt hypothesis unless confirmed by telemetry.
Telemetry suppression	Defense Impairment	Disable or Modify Tools (T1685); Disable or Modify Cloud Log (T1685.002) or Windows Event Log (T1685.001) where applicable	Log forwarding, event collection, or alert metrics may be modified so the platform appears healthy while control outcomes fail.
Core impact	Impact	Data Manipulation (T1565)	The scenario's core effect is manipulation of data or logic to influence business and compliance outcomes.
Stored rule/data change	Impact	Stored Data Manipulation (T1565.001)	Screening rules, watchlists, reference data, exception tables, or fail-open flags stored in the platform are altered to change decisioning.
Containment-driven interruption	Impact / Response consequence	Service Stop (T1489) – response/conditional	Payment or screening services may be stopped or disconnected as a containment action; use only if adversary or response actions actually stop services.

End of exercise document. MITRE ATT&CK; mapping is intentionally placed at the end to support facilitation, scoring, and after-action control mapping.